Avaliação da Qualidade de Software: Estudo de Caso do draw.io

Heyttor Augusto de Assis Silva[1], **Lucas Gabriel Gomes Aguiar**[1]
Miquéias Ezequiel Gonçalves Carvalho[1], **Yasmin Sousa Abdon**[1]
Pedro Ian Guedes de Carvalho[1], **Thiago Gomes Pereira de Abreu**[1]

[1]Faculdade de Ciências e Tecnologias em Engenharia (FCTE)
Universidade de Brasília (UnB)
Engenharia de Software – Brasília – DF – Brasil

Abstract. *This paper presents the planning of a software quality assessment of draw.io, considering security, performance efficiency, and maintainability, according to ISO/IEC 25010. The assessment uses the Goal-Question-Metric (GQM) method to relate quality goals to the established questions and metrics. The study covers the analysis of selected software components and functionalities through metrics and procedures appropriate to each quality characteristic. For maintainability, static analysis using SonarCloud is planned. The results will be presented after the collection and analysis of the metrics.*

Resumo. *Este artigo apresenta o planejamento de uma avaliação da qualidade do software draw.io, considerando as características de segurança, eficiência de desempenho e manutenibilidade, conforme a ISO/IEC 25010. A avaliação utiliza o método Goal-Question-Metric (GQM) para relacionar os objetivos de qualidade às questões e métricas estabelecidas. O estudo contempla a análise de componentes e funcionalidades selecionados do software, por meio de métricas e procedimentos adequados a cada característica. Para a manutenibilidade, prevê-se a utilização de análise estática com o SonarCloud. Os resultados serão apresentados após a coleta e análise das métricas.*

1. Introdução

Uma diretoria de TI de uma empresa júnior de software, em cenário hipotético, considera hospedar uma ferramenta de diagramas em infraestrutura própria para produzir artefatos de arquitetura, UML e bancos de dados para seus clientes. Antes de adotá-la, precisa de evidências de que a ferramenta é segura, suporta a carga de trabalho e pode ser mantida pela equipe.

O objeto da avaliação é o *draw.io*, também conhecido como diagrams.net, ferramenta de código aberto para criar e editar diagramas, usada no navegador ou instalada localmente, que exporta em formatos como PNG, PDF e SVG (JGraph, sd). O recorte cobre três componentes do fluxo central de uso: importação de arquivos, edição de rótulos e exportação; a versão e o ambiente de execução serão definidos no plano de avaliação (Fase 3).

O objetivo é apoiar a decisão de adoção, avaliando a segurança, a eficiência de desempenho e a manutenibilidade segundo a ISO/IEC 25010:2023 (ISO/IEC, 2023). A

equipe atua como avaliadora externa, e o relatório final permitirá ao requisitante escolher entre adotar, adotar com ressalvas ou não adotar a ferramenta. Os artefatos do projeto estão no repositório da equipe[1].

O artigo está organizado da seguinte forma: a Seção 2 apresenta o referencial teórico; a Seção 3, a metodologia; a Seção 4, os requisitos da avaliação (Fase 1); e a Seção 5, a especificação da avaliação com o GQM (Fase 2). Os resultados serão apresentados na Entrega 2.

2. Referencial Teórico

2.1. Segurança

Duas classes de falha são relevantes para este estudo. No *Stored Cross-Site Scripting* (XSS), um conteúdo malicioso armazenado na aplicação é executado no navegador da vítima ao ser acessado (Hannousse et al., 2024, Seção 6.1), o que pode resultar no roubo de *cookies* e no comprometimento de dados do usuário (M et al., 2022, p. 1). A principal linha de defesa é a sanitização das entradas (M et al., 2022, p. 12), embora ela possa ser burlada por variações do ataque (Hannousse et al., 2024, Seção 7.1.1). No *Path Traversal*, requisições manipuladas alcançam arquivos e diretórios fora do escopo permitido, ameaçando a confidencialidade, a integridade e a disponibilidade do sistema (Akhoundali et al., 2025, p. 542–543).

2.2. Eficiência de desempenho

Na ISO/IEC 25010:2023, a eficiência de desempenho se divide em três subcaracterísticas: comportamento temporal, que trata de quanto os tempos de resposta e de processamento e as taxas de vazão de um produto atendem aos requisitos; utilização de recursos, que trata de quanto as quantidades e os tipos de recursos consumidos atendem aos requisitos; e capacidade, que trata de quanto os limites máximos de um parâmetro do produto, como a quantidade de itens que ele suporta, atendem aos requisitos (ISO/IEC, 2023, Seção 3.2). Em aplicações web, a avaliação de desempenho costuma observar a responsividade, a vazão e a escalabilidade sob cargas crescentes (Alnuhait et al., 2024).

2.3. Manutenibilidade

Na ISO/IEC 25010:2023, a manutenibilidade representa o grau de eficácia e eficiência com que um produto pode ser modificado para melhorá-lo, corrigi-lo ou adaptá-lo a mudanças (ISO/IEC, 2023, Seção 3.6). Este estudo considera duas de suas subcaracterísticas: a analisabilidade, que trata de quanto é fácil diagnosticar deficiências e identificar partes a modificar, e a modificabilidade, que trata de quanto o produto pode ser alterado sem introduzir defeitos (ISO/IEC, 2023, Seção 3.6). Dois aspectos do código as influenciam diretamente: a duplicação, que multiplica os pontos de alteração e favorece inconsistências Lozano and Wermelinger (2008), e a complexidade cognitiva, que mede a dificuldade de compreensão do código Campbell (2018); Muñoz Barón et al. (2020)

[1] `https://github.com/FCTE-Qualidade-de-Software-1/2026-2_T01_MARY_JACKSON`

3. Metodologia

A avaliação segue o processo de avaliação de produto apresentado na disciplina (Ramos, 2026), adaptado da ISO/IEC 25040 (ISO/IEC, 2024), com quatro fases divididas em duas entregas.

Entrega 1 – especificar a avaliação. Na **Fase 1 (Estabelecer os requisitos)**, a equipe definiu o propósito da avaliação, o requisitante e o cenário, o produto e os componentes avaliados e o modelo de qualidade, selecionando três características da ISO/IEC 25010:2023, cada uma com nota de ênfase de 1 a 5. Na **Fase 2 (Especificar a avaliação)**, cada característica foi desdobrada com o método GQM (Basili and Weiss, 1984; Ramos, 2026) em objetivo, questões, hipóteses e métricas, com base nas medidas da ISO/IEC 25023 (ISO/IEC, 2011), e foram definidos os níveis de pontuação e os critérios de julgamento.

Entrega 2 – executar a avaliação. Na **Fase 3 (Projetar a avaliação)**, serão definidos o plano de avaliação, a versão do produto, o ambiente e as ferramentas de coleta. Na **Fase 4 (Executar a avaliação)**, as medidas serão coletadas, comparadas com os critérios de julgamento e usadas para responder às questões e apoiar a decisão do requisitante.

4. Fase 1: Requisitos da Avaliação

4.1. Segurança

A segurança foi selecionada porque a empresa júnior hospedaria o editor em infraestrutura própria, e uma falha expõe os dados estratégicos e os acessos em nuvem da empresa e de seus clientes. Os avisos de segurança do *draw.io* registram que as falhas de XSS nos rótulos afetavam instalações próprias sem política de segurança de conteúdo (CSP) restritiva, enquanto o serviço público não era explorável (JGraph, 2026). A nota de ênfase é **5/5** e representa a prioridade da característica, não um resultado medido.

A avaliação está delimitada a três componentes que processam entradas externas e registram três vulnerabilidades conhecidas, todas corrigidas antes da versão avaliada. Na **importação de arquivos**, a abertura de diagramas recebidos de terceiros disparava as falhas de XSS nos rótulos (JGraph, 2026). No **tratamento de rótulos**, ocorreram o XSS armazenado da CVE-2026-46642 e seu contorno por variação do ataque, na CVE-2026-58504 (JGraph, 2026). No ***proxy* de exportação**, o *Path Traversal* da CVE-2026-63416 permitia alcançar recursos internos do servidor (National Vulnerability Database, 2026).

O recorte considera as três subcaracterísticas descritas na Seção 2.1. A resistência foi incluída porque a primeira correção de XSS do *draw.io* foi contornada. Ficam fora do escopo a segurança dos provedores de nuvem e as políticas de rede da organização.

4.2. Eficiência de Desempenho

A eficiência de desempenho foi selecionada porque atrasos e consumo excessivo de memória podem interromper o fluxo de criação de diagramas. O recorte contempla comportamento temporal, utilização de recursos e capacidade (ISO/IEC, 2023), do ponto

de vista dos usuários finais da empresa júnior. Propõe-se importância **4/5** para essa característica: ela afeta todas as operações do fluxo principal (abrir, editar e exportar), mas, ao contrário de uma falha de segurança, um problema de desempenho atrasa o trabalho sem expor os dados dos usuários. Essa prioridade deverá ser conciliada com as demais características e validada pelo requisitante, a diretoria de TI de uma empresa júnior de software (cenário hipotético). Trata-se de importância para a avaliação, não de nota de desempenho do produto.

As cargas de 50, 300, 1.000, 2.000 e 5.000 formas permitem comparar portes controlados. Aqui, abrir significa substituir o documento por *Abrir de/Dispositivo*, distinguindo essa operação da inserção de elementos no diagrama corrente. A Seção 5.3 detalha a avaliação dessa característica por meio do objetivo G2.

4.3. Manutenibilidade

A manutenibilidade foi selecionada para apoiar a decisão de adoção do *draw.io* por uma empresa júnior de software que considera hospedar o editor em infraestrutura própria. A avaliação busca identificar se é viável analisar, corrigir e adaptar o código dos componentes selecionados caso a empresa mantenha uma versão própria. A nota de ênfase é **4/5** e representa a prioridade da característica, não um resultado medido.

A avaliação considera o código-fonte do *draw.io* web, e está delimitada a três componentes associados ao fluxo de **abrir diagramas**, **editar rótulos** e **exportar arquivos** (JGraph, sd). Com base no modelo de qualidade da ISO/IEC 25010:2023 será examinada a complexidade cognitiva média por função nos componentes de importação e edição de rótulos e pelo percentual de código duplicado entre as implementações de exportação PNG, PDF e SVG.

A prioridade permanece abaixo da máxima porque a análise não cobre a manutenção do produto inteiro. Mudanças nos formatos de arquivo e na representação dos diagramas podem gerar regressões em outras operações, aspecto que limita o alcance das conclusões deste recorte.

5. Fase 2: Especificação da Avaliação

5.1. Rastreabilidade entre as Fases 1 e 2

A avaliação foi planejada com a abordagem GQM (*Goal-Question-Metric*), que deriva métricas de objetivos de medição por meio de questões, garantindo que cada medição atenda a uma decisão do requisitante.

A Figura 1 consolida as três hierarquias GQM em uma única visão, apenas com os identificadores. Ela mostra como cada objetivo (G1, G2 e G3) se desdobra em questões e como cada questão é respondida por uma ou mais métricas. O conteúdo de cada elemento é detalhado nas subseções de cada objetivo.

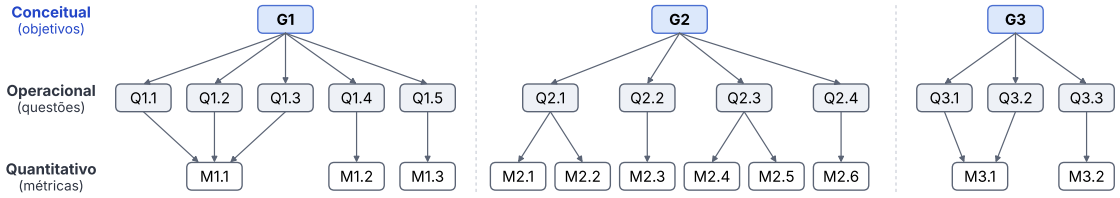


Figura 1. Visão consolidada da hierarquia GQM da avaliação. Fonte: elaboração da equipe.

5.1.1. Questões e hipóteses da avaliação

A Tabela 1 reúne os 12 pares de questões e hipóteses, agrupados por característica de qualidade e objetivo GQM. Cada linha associa uma questão (Q) à hipótese correspondente (H). As hipóteses serão verificadas na Entrega 2 (E2).

Tabela 1. Questões e hipóteses da avaliação por característica

Questão	Hipótese
Segurança (G1)	
Q1.1 Qual a taxa de bloqueio de arquivos de teste com conteúdo malicioso na importação de diagramas?	**H1.1** O componente de importação bloqueia todos os casos de teste aplicados (M1.1 = 100%).
Q1.2 Qual a taxa de bloqueio de rótulos de teste com conteúdo malicioso na exibição das formas?	**H1.2** O tratamento de rótulos sanitiza o conteúdo e bloqueia todos os casos de teste aplicados (M1.1 = 100%).
Q1.3 Qual a taxa de bloqueio de requisições de teste com caminhos indevidos ao *proxy* de exportação?	**H1.3** O *proxy* de exportação rejeita todas as requisições de teste com caminhos indevidos (M1.1 = 100%).
Q1.4 Qual a proporção de trechos que exibem rótulos em HTML com sanitização ou escape prévios?	**H1.4** Todos esses trechos aplicam proteção na versão avaliada, ao contrário do trecho que originou a CVE-2026-46642 (M1.2 = 100%).
Q1.5 Qual a taxa de bloqueio de variações dos ataques conhecidos, incluindo combinações de estilos de formas?	**H1.5** Nenhuma das variações testadas executa código na abertura do arquivo (M1.3 = 100%).
Eficiência de desempenho (G2)	
Q2.1 Como o tempo de abertura e o consumo de memória variam à medida que o porte do diagrama aumenta?	**H2.1** Ambos crescem com o porte, mas permanecem dentro dos limites de cada carga (nota 4 ou 5 em M2.1 e M2.2).
Q2.2 Em que medida a edição de rótulos permanece responsiva à medida que o número de formas aumenta?	**H2.2** A latência cresce com o porte, mas atende ao limite de cada carga (nota 4 ou 5 em M2.3).

Continua na próxima página.

Tabela 1. Questões e hipóteses da avaliação por característica (continuação)

Questão	Hipótese
Q2.3 Como os formatos PNG, PDF e SVG diferem em tempo de exportação e pico de memória?	**H2.3** Os custos variam por formato, e todos atendem aos limites de cada carga (nota 4 ou 5 em M2.4 e M2.5).
Q2.4 Qual o maior porte de diagrama em que o fluxo abrir, editar e exportar é concluído de forma repetível?	**H2.4** Com 5.000 formas, cada uma das cinco operações terá pelo menos quatro sucessos em cinco tentativas válidas (M2.6 = 5.000 formas).
Manutenibilidade (G3)	
Q3.1 Em que medida a complexidade do código responsável pela leitura e conversão de arquivos pode dificultar sua compreensão e manutenção?	**H3.1** O código de importação apresenta complexidade cognitiva média inferior ou igual a 10 por função.
Q3.2 Em que medida a complexidade do código responsável pela edição e formatação de rótulos pode dificultar sua compreensão e manutenção?	**H3.2** O código de edição de rótulos apresenta complexidade cognitiva média inferior ou igual a 10 por função.
Q3.3 Em que medida a duplicação de código entre as implementações de exportação PNG, PDF e SVG pode dificultar futuras modificações?	**H3.3** O percentual de código duplicado no escopo de exportação é inferior ou igual a 5%.

5.2. Avaliação da Segurança

5.2.1. Objetivo de Medição

Tabela 2. Objetivo GQM de segurança

Elemento	Descrição
Analisar	O *draw.io* (G1).
Para o propósito de	Entender.
Com respeito a	Segurança (confidencialidade, integridade e resistência).
Do ponto de vista de	Diretoria de TI.
No contexto de	adoção do draw.io por uma empresa júnior de software.

5.2.2. Questões e Hipóteses

As questões e hipóteses de segurança estão no bloco G1 da Tabela 1. As questões Q1.1 a Q1.3 medem a taxa de bloqueio de casos de teste baseados nas vulnerabilidades conhecidas, uma por componente; Q1.4 e Q1.5 avaliam a qualidade da proteção dos rótulos.

5.2.3. Métricas e critérios de julgamento

A Tabela 3 resume as três métricas de Segurança. M1.1 e M1.3 serão coletadas por testes em ambiente local, e M1.2, por inspeção do código-fonte. As métricas seguem a forma de proporção ($X = A/B$) adotada pela ISO/IEC 25023 para as medidas de segurança (ISO/IEC, 2011): M1.1 e M1.3 serão adaptadas de *access controllability* (seção 8.6.1, p. 27) e seguirão a recomendação de testes de penetração da Nota 1 da seção 8.6 (p. 26); M1.2 será adaptada de *data corruption prevention* (seção 8.6.2, p. 27), contando trechos protegidos em vez de danos ocorridos. Karnouskos et al. (2018) discutem a aplicabilidade dessas medidas da norma e mostram que algumas podem ser verificadas antes da implantação, por lista de verificação.

Tabela 3. Métricas, cálculo e evidências de segurança. Fonte: elaboração da dupla.

ID/questão	Definição e cálculo	Fonte/unidade
M1.1 / Q1.1, Q1.2, Q1.3	Taxa de bloqueio: percentual de casos de teste maliciosos bloqueados, calculada separadamente para importação, rótulos e *proxy* de exportação; $M1.1 = (C_b/C_t) \times 100$.	Testes em ambiente local; %.
M1.2 / Q1.4	Proporção de trechos de renderização de rótulos HTML que aplicam sanitização ou escape; $M1.2 = (P_p/P_t) \times 100$.	Inspeção do código-fonte; %.
M1.3 / Q1.5	Taxa de bloqueio: percentual de variações dos ataques conhecidos bloqueadas; $M1.3 = (W_b/W_t) \times 100$.	Testes em ambiente local; %.

A Tabela 4 apresenta a escala. M1.1 e M1.3 não têm nota intermediária, pois a execução de um único caso malicioso já é falha crítica.

Tabela 4. Escala de pontuação das métricas de segurança. Fonte: proposta da dupla.

Métrica	Nota 5 (Adequado)	Nota 3 (Atenção)	Nota 1 (Crítico)
M1.1 (%)	100%	—	menor que 100%
M1.2 (%)	100%	menor que 100%, sem trecho alcançável por arquivo aberto	menor que 100%, com trecho alcançável por arquivo aberto
M1.3 (%)	100%	—	menor que 100%

Na consolidação, Q1.1 a Q1.3 recebem a nota de M1.1 no respectivo componente, Q1.4 a de M1.2 e Q1.5 a de M1.3; a nota de G1 é o mínimo entre as cinco questões. Nota 5 indica **adotar**; nota 3, **adotar com ressalvas**, com controles compensatórios; e nota 1, **não adotar sem atualização**. Dados ausentes ou testes incompletos impedem a nota global. Esses níveis são decisões da equipe, não critérios normativos da ISO/IEC.

5.2.4. Protocolo de Coleta

Versão, ambiente e código-fonte analisado serão definidos no plano de avaliação (Fase 3). M1.1 e M1.3 serão coletadas por testes sem acesso à rede externa, em sessão limpa do navegador, com casos construídos a partir dos avisos das três CVEs e com variações do

conteúdo dos rótulos e da combinação de estilos das formas. M1.2 será coletada pela inspeção das chamadas `getLabelValue` em `Format.js`, `Graph.js` e `Editor.js`, verificando o uso de `Graph.sanitizeHtml` ou `mxUtils.htmlEntities`. Bibliotecas de terceiros e código gerado ficam fora da análise. Por divulgação responsável, os arquivos de teste não serão publicados; o repositório registra apenas a descrição de cada caso e o resultado.

5.3. Avaliação da Eficiência de Desempenho

5.3.1. Objetivo de Medição

Tabela 5. Objetivo GQM de eficiência de desempenho

Elemento	Descrição
Identificador	G2
Analisar	O *draw.io*.
Para o propósito de	Entender.
Com respeito a	ficiência de desempenho (comportamento temporal, utilização de recursos e capacidade).
Do ponto de vista de	Usuários finais da empresa júnior (desenvolvedores, analistas e gerentes de projeto).
No contexto de	adoção do *draw.io* por uma empresa júnior de software.

5.3.2. Questões e Hipóteses

As questões Q2.1 a Q2.4 e suas hipóteses estão no bloco G2 da Tabela 1.

5.3.3. Métricas e critérios de julgamento

A Tabela 6 resume as seis métricas. Para cada porte e operação/formato, serão realizadas cinco tentativas válidas; interrupções externas serão registradas e repostas. Para M2.1–M2.5, calcula-se a mediana x das quatro ou cinco tentativas bem-sucedidas com dados completos; menos de quatro sucessos tornam o cenário não conclusivo. Falhas não recebem valores artificiais de tempo ou memória. As durações são $t_f - t_i$, sem incluir digitação ou navegação humana nos seletores.

Os limites L da Tabela 7 são **candidatos, ainda não aprovados**; a tolerância crescente por porte e a distinção por formato serão avaliadas no piloto e aprovadas pelo requisitante antes da coleta.

Para M2.1–M2.5, $r = x/L$, com $L > 0$ da mesma métrica, carga e formato: **5** se $0 \leq r \leq 0{,}5$; **4** se $0{,}5 < r \leq 1$; **3** se $1 < r \leq 1{,}5$; **2** se $1{,}5 < r \leq 2$; **1** se $r > 2$. A nota da métrica é a menor entre seus cenários, com medianas e notas de cada cenário preservadas no registro.

Para M2.6, todos os cinco portes devem ser ensaiados; o maior aprovado recebe nota **5** para 5.000 formas, **4** para 2.000, **3** para 1.000, **2** para 300 e **1** para 50 ou nenhum

Tabela 6. Métricas, cálculo e evidências. Fonte: elaboração da dupla.

ID/questão	Definição e cálculo por cenário	Fonte/unidade
M2.1/Q2.1	Tempo da confirmação de abertura até o diagrama estável e interativo; mediana por porte.	Vídeo/trace; ms.
M2.2/Q2.1	Heap JS usado 2 s após a estabilização da abertura; mediana por porte.	DevTools; MiB.
M2.3/Q2.2	Latência da confirmação do novo rótulo até sua renderização estável; mediana por porte.	Vídeo/trace; ms.
M2.4/Q2.3	Tempo da confirmação final da exportação até o arquivo íntegro disponível; mediana por porte/formato.	Vídeo/arquivo; ms.
M2.5/Q2.3	Máximo do heap JS na janela de M2.4; mediana dos picos por porte/formato.	DevTools; MiB.
M2.6/Q2.4	Maior porte com ao menos 4/5 sucessos em cada operação: abrir, rótulo e exportar PNG, PDF e SVG.	CSV/arquivos; formas.

Tabela 7. Limites candidatos L, não aprovados. Fonte: proposta da dupla.

Métrica/unidade	50	300	1.000	2.000	5.000
M2.1 abrir (ms)	2.000	3.500	6.500	11.000	24.000
M2.2 heap após abrir (MiB)	120	170	280	440	800
M2.3 rótulo (ms)	300	450	700	1.100	1.800
M2.4 PNG (ms)	4.000	6.000	11.000	20.000	45.000
M2.4 PDF (ms)	7.000	10.000	20.000	35.000	75.000
M2.4 SVG (ms)	3.000	5.000	9.000	17.000	40.000
M2.5 PNG (MiB)	180	240	400	650	1.100
M2.5 PDF (MiB)	180	240	400	650	1.100
M2.5 SVG (MiB)	170	230	380	620	1.050

porte aprovado, distinguindo estes dois casos. Amostras incompletas não demonstram limite de capacidade. Propõe-se Q2.1 = mínimo(M2.1,M2.2), Q2.2 = M2.3, Q2.3 = mínimo(M2.4,M2.5), Q2.4 = M2.6 e G2 = mínimo(Q2.1–Q2.4). Dados ausentes, instrumentos inviáveis ou critérios não aprovados impedem a nota global; informa-se avaliação parcial. Esses níveis são decisões da equipe, não critérios normativos da ISO.

5.3.4. Coleta prevista e rastreabilidade

Os cinco arquivos sintéticos serão identificados por hash; versão/build, navegador, hardware, cache e opções de exportação serão registrados, restaurando o estado de referência entre tentativas. Na forma `v0001`, o rótulo será alterado de `Rotulo 0001` para `Rotulo A001`. Vídeo/trace e DevTools fornecerão as leituras da Tabela 6, com resolução de amostragem declarada; valores de memória em bytes serão convertidos por $\mathrm{MiB} = \mathrm{bytes}/2^{20}$. Cada arquivo exportado será validado no formato solicitado. As fichas completas e a planilha de coleta permanecerão no repositório. O piloto verificará a viabilidade dos instrumentos; XML válido não comprova execução no draw.io, e a coleta definitiva ocorrerá na E2.

5.4. Avaliação da Manutenibilidade

5.4.1. Objetivo de Medição

Tabela 8. Objetivo GQM de manutenibilidade

Elemento	Descrição
Identificador	G3
Analisar	*draw.io*.
Para o propósito de	Entender
Com respeito a	Manutenibilidade: analisabilidade e modificabilidade.
Ponto de vista	Equipe Mary Jackson, responsável pela avaliação.
Contexto	Disciplina Qualidade de Software 1 e cenário hipotético de adoção do *draw.io* por uma empresa júnior de software.

5.4.2. Questões e Hipóteses

As questões Q3.1 a Q3.3 e suas hipóteses estão no bloco G3 da Tabela 1 e orientam a avaliação da manutenibilidade dos três componentes selecionados.

5.4.3. Métricas de Manutenibilidade

Foram selecionadas duas métricas para responder às três questões estabelecidas, sendo a primeira aplicada separadamente aos componentes de importação de arquivos e edição de rótulos, e a segunda ao código responsável pela exportação de arquivos. A coleta das métricas será realizada por meio de análise estática utilizando o SonarCloud.

Tabela 9. Fichas das métricas de manutenibilidade

Campo	M3.1	M3.2
Métrica	Complexidade cognitiva média por função.	Percentual de código duplicado.
Subcaracterística	Analisabilidade.	Modificabilidade.
Questão associada	Q3.1 e Q3.2.	Q3.3.
Componente	Importação de arquivos e edição de rótulos, analisados separadamente.	Exportação PNG, PDF e SVG.
Definição	Média da complexidade cognitiva das funções pertencentes ao componente analisado.	Percentual de linhas duplicadas em relação ao total de linhas analisadas no código de exportação.
Cálculo	$M_{3.1} = \frac{C}{F}$	$M_{3.2} = \frac{L_d}{L_t} \times 100$

Tabela 9. Fichas das métricas de manutenibilidade (continuação)

Campo	M3.1	M3.2
Fonte	SonarCloud.	SonarCloud.
Coleta	Identificar as funções pertencentes a cada componente e registrar a complexidade cognitiva total e a quantidade de funções, separadamente para importação e rótulos.	Analisar conjuntamente os arquivos de exportação e registrar a quantidade de linhas duplicadas e o total de linhas analisadas.
Critério de julgamento	Adequado: $M_{3.1} \leq 10$. Atenção: $10 < M_{3.1} \leq 15$. Crítico: $M_{3.1} > 15$.	Adequado: $M_{3.2} \leq 5\%$. Atenção: $5\% < M_{3.2} \leq 10\%$. Crítico: $M_{3.2} > 10\%$.

Nota: C representa a complexidade cognitiva total das funções analisadas; F, a quantidade de funções; L_d, as linhas duplicadas; e L_t, o total de linhas analisadas no escopo de exportação.

Os limites são critérios preliminares propostos para esta avaliação, não valores normativos da ISO/IEC 25010:2023. Cada componente de M3.1 recebe julgamento separado (Q3.1 e Q3.2), e M3.2 responde à Q3.3. Não foi definido um critério para agregar os julgamentos em um resultado único para G3.

5.4.4. Protocolo de Coleta

Antes da coleta, fixar a tag ou o commit do código-fonte correspondente ao *draw.io* web 32.2.0 e registrar a identificação exata da versão analisada. Documentar os arquivos incluídos em cada componente (importação, edição de rótulos e exportação PNG, PDF e SVG), para que o escopo possa ser reproduzido.

Realizar a análise estática no SonarCloud. Para M3.1, identificar as funções de importação e de edição de rótulos e registrar, separadamente para cada componente, a complexidade cognitiva total (C), a quantidade de funções (F) e a média C/F. Para M3.2, analisar conjuntamente o código de exportação dos três formatos e registrar as linhas duplicadas (L_d), o total de linhas analisadas (L_t) e o percentual $L_d/L_t \times 100$.

Excluir arquivos de bibliotecas externas, dependências e códigos gerados automaticamente que não pertençam às implementações avaliadas. Registrar os dados de origem e os resultados das métricas sem inferir um julgamento agregado para G3.

Na análise de duplicação, identificar trechos repetidos entre as implementações de exportação PNG, PDF e SVG e distingui-los de duplicações internas a um único formato.

Referências

Akhoundali, J., Hamidi, H., Rietveld, K., and Gadyatskaya, O. (2025). Eradicating the Unseen: Detecting, Exploiting, and Remediating a Path Traversal Vulnerability across GitHub. In *Proceedings of the ACM Asia Conference on Computer and Communications Security (ASIA CCS '25)*, pages 542–558, Hanoi, Vietnam. ACM.

Alnuhait, H., Alzyadat, W., Althunibat, A., Kahtan, H., Zaqaibeh, B., and Al-Khawaja, H. A. (2024). Web application performance assessment: A study of responsiveness, throughput, and scalability. *International Journal of Advanced and Applied Sciences*, 11(9):214–226. Disponível em: https://doi.org/10.21833/ijaas.2024.09.023. Acesso em: 23 out. 2026.

Basili, V. R. and Weiss, D. M. (1984). A Methodology for Collecting Valid Software Engineering Data. *IEEE Transactions on Software Engineering*, SE-10(6):728–738. Disponível em: https://doi.org/10.1109/TSE.1984.5010301. Acesso em: 23 out. 2026.

Campbell, G. A. (2018). Cognitive complexity: An overview and evaluation. In *Proceedings of the International Conference on Technical Debt (TechDebt)*, pages 57–58. ACM.

Hannousse, A., Yahiouche, S., and Nait-Hamoud, M. C. (2024). Twenty-two years since revealing cross-site scripting attacks: a systematic mapping and a comprehensive survey. *Computer Science Review*, 52:100634.

ISO/IEC (2011). ISO/IEC WD 25023: Systems and software engineering – systems and software quality requirements and evaluation (SQuaRE) – measurement of system and software product quality. Working Draft ISO/IEC WD 25023, ISO/IEC JTC 1/SC 7/WG 6. Versão 0.1.0, datada de 31 ago. 2011; o próprio arquivo informa que não é uma norma internacional publicada.

ISO/IEC (2023). Systems and software engineering – Systems and software Quality Requirements and Evaluation (SQuaRE) – Product quality model. International Standard ISO/IEC 25010:2023, International Organization for Standardization, Geneva. Disponível em: https://www.iso.org/standard/78176.html. Acesso em: 17 out. 2026.

ISO/IEC (2024). Systems and software engineering – Systems and software Quality Requirements and Evaluation (SQuaRE) – Quality evaluation framework. International Standard ISO/IEC 25040:2024, International Organization for Standardization, Geneva. Disponível em: https://www.iso.org/standard/83467.html. Acesso em: 20 out. 2026.

JGraph (2026a). draw.io: Stored xss on file open via editable=0 sibling cell (ghsa-c76x-r78m-phwx). GitHub Security Advisory. Disponível em: https://github.com/jgraph/drawio/security/advisories/GHSA-c76x-r78m-phwx. Acesso em: 20 out. 2026.

JGraph (2026b). draw.io: Xss via crafted cell label when opening a .drawio file (ghsa-fqhg-287p-c6vf). GitHub Security Advisory. Disponível em: https://github.com/jgraph/drawio/security/advisories/GHSA-fqhg-287p-c6vf. Acesso em: 20 out. 2026.

JGraph (s.d.). draw.io: source code repository. GitHub. Disponível em: https://github.com/jgraph/drawio. Acesso em: 17 out. 2026.

Karnouskos, S., Sinha, R., Leitão, P., Ribeiro, L., and Strasser, T. I. (2018). The Applicability of ISO/IEC 25023 Measures to the Integration of Agents and Automation Systems. In *Proceedings of the 44th Annual Conference of the IEEE Industrial Electronics Society (IECON 2018)*, pages 2927–2934, Washington, DC, USA. IEEE.

Lozano, A. and Wermelinger, M. (2008). Assessing the effect of clones on changeability. In *Proceedings of the IEEE International Conference on Software Maintenance (ICSM)*, pages 227–236. IEEE.

M, I., Kaur, M., Raj, M., R, S., and Lee, H.-N. (2022). Cross Channel Scripting and Code Injection Attacks on Web and Cloud-Based Applications: A Comprehensive Review. *Sensors*, 22(5):1959. Artigo 1959. Disponível em: `https://doi.org/10.3390/s22051959`. Acesso em: 23 out. 2026.

Muñoz Barón, M., Wyrich, M., and Wagner, S. (2020). An empirical validation of cognitive complexity as a measure of source code understandability. In *Proceedings of the ACM/IEEE International Symposium on Empirical Software Engineering and Measurement (ESEM)*, pages 1–12. ACM.

National Vulnerability Database (2026). CVE-2026-63416. NIST. Disponível em: `https://nvd.nist.gov/vuln/detail/CVE-2026-63416`. Acesso em: 20 out. 2026.

Ramos, C. S. (2026a). Medição baseada em objetivos: determinando o que medir. Material didático (slides) da disciplina Qualidade de Software 1, Universidade de Brasília, Faculdade do Gama. Aula 08, material datado de 5 out. 2026. Baseado em material de aula de Káthia Marçal Oliveira.

Ramos, C. S. (2026b). Processo de avaliação de produto de software. Material didático (slides) da disciplina Qualidade de Software 1, Universidade de Brasília, Faculdade do Gama. Aula 07; material datado de 5 out. 2026.

A. Tabela de Contribuição

O percentual de cada integrante corresponde às horas registradas no repositório (arquivo de horas e campo "Horas reais" das *issues*) até 26/10/2026. O total da Entrega 1 foi de 114,4 horas, e os percentuais foram arredondados. Os dados completos estão na Medição 3 do Registro de medições da GitPage.

Tabela 10. Contribuição dos integrantes na Entrega 1. Fonte: Painel do PSM e Registro de medições (Medição 3).

Integrante	Principais responsabilidades	Horas	%
Yasmin Sousa Abdon	Gestão do projeto (planejamento, *issues*, painel do PSM, plano de medição, medições e atas); GQM e fichas de Segurança; revisão da Fase 1 de Segurança e dos ODS; Referencial do artigo; reescrita da Introdução e da Metodologia; reorganização do artigo para a E1	37,9	33
Heyttor Augusto de Assis Silva	GQM, métricas e diagramas de Manutenibilidade; revisão cruzada; montagem do artigo	20,8	18
Pedro Ian Guedes de Carvalho	GQM de Eficiência; Fase 1 na GitPage; rastreabilidade Fase 1 $\rightarrow$ Fase 2	16,5	14
Lucas Gabriel Gomes Aguiar	GQM de Manutenibilidade; ambiente Docker (Fase 3); referências; montagem do artigo; piloto do SonarCloud	14,8	13
Miquéias Ezequiel Gonçalves Carvalho	Justificativa e ODS de Segurança; objetivo GQM de Segurança; versão inicial da Introdução e da Metodologia	13,8	12
Thiago Gomes Pereira de Abreu	Eficiência; identidade visual e páginas da GitPage; modelo de qualidade	10,5	9
Total		**114,4**	**100**